

Narrativa Explicativa

GQM + PRAGMATIC al Servicio de la Pirámide del Dolor

Los modelos conceptuales tienen una virtud y un defecto. La virtud es que simplifican la realidad en formas que podemos entender; el defecto es que, tarde o temprano, alguien intenta meterlos en un Excel. La Pirámide del Dolor no se salva de este destino: lo que empezó como un recordatorio visual sobre el valor relativo de los indicadores ha acabado pidiendo métricas, objetivos y cuadros de mando.

La buena noticia es que existen enfoques pensados precisamente para evitar que ese viaje de la pizarra al fichero .xlsx se convierta en una sucesión de ocurrencias. GQM y PRAGMATIC no son nombres de proyectos europeos, aunque lo parezcan, sino dos formas complementarias de mantener la cordura cuando hablamos de medir cosas complejas.

Del “qué queremos lograr” al “qué demonios medimos”: GQM

GQM (Goal–Question–Metric) propone algo escandalosamente sensato: antes de decidir qué datos recoger, aclaremos qué objetivos perseguimos, qué preguntas dan cuerpo a esos objetivos y qué métricas pueden responderlas. En el contexto de la Pirámide del Dolor, esto significa, por ejemplo:

- No empezar por “¿cuántos hashes bloqueamos al mes?”.
- Sino por “¿queremos reducir nuestra dependencia de indicadores efímeros y aumentar la detección basada en comportamiento?”.
- Y sólo entonces preguntar “¿qué tendría que ver en los datos para saber si eso está ocurriendo?”.

Aplicado a escala nacional, GQM ayuda a trazar una línea clara desde objetivos de alto nivel (“reducir impacto de ataques en servicios esenciales”) hasta métricas muy concretas (“porcentaje de incidentes críticos detectados inicialmente por reglas TTP”). Esa trazabilidad hace que los indicadores dejen de ser un fin en sí mismos y se conviertan, como debe ser, en instrumentos.

PRAGMATIC: la criba cínica que toda métrica merece

Por muy elegante que sea un objetivo y por muy bien formulada que esté una pregunta, siempre acecha el peligro de la métrica inútil: ese número que es costoso de obtener, difícil de interpretar y que, una vez en el informe, nadie sabe muy bien qué hacer con él. Aquí entra PRAGMATIC, que no es una filosofía de vida (aunque podría) sino una lista de comprobación:

- ¿La métrica es predictiva, o sólo describe el pasado?
- ¿Es relevante para lo que realmente importa?
- ¿Es accionable, es decir, su variación sugiere decisiones claras?
- ¿Es genuina, o se presta a ser manipulada fácilmente?
- ¿Es significativa para las personas que la van a ver?
- ¿Es precisa y consistente, o una estimación vaga?
- ¿Es oportuna, llega a tiempo para influir en decisiones?
- ¿Es independiente, aporta información nueva?
- ¿Es rentable, es decir, su coste no supera su utilidad?

Pasar cada métrica por este tamiz puede resultar doloroso (otra vez la metáfora), pero es un dolor saludable. Obliga a descartar indicadores conceptualmente bonitos que, en la práctica, sólo servirían para impresionar a quien no pregunte demasiado.

Por qué esto importa a nivel nacional

Cuando se habla de estrategias nacionales de ciberseguridad, la tentación de medirlo todo es enorme, y el riesgo de medir lo equivocado, también. La Pirámide del Dolor sugiere una jerarquía: dedicar más atención (y métricas) a aquello que empuja al adversario a cambiar procesos y menos a los indicadores triviales. GQM+PRAGMATIC traduce esa intuición en un proceso disciplinado:

1. Formulamos objetivos estratégicos claros: más detección TTP, mejor uso de IoC, mayor calidad de intercambio de información.
2. Derivamos preguntas concretas: ¿qué proporción de incidentes se detectan por TTP? ¿cuánto tarda en llegar un IoC útil? ¿qué se hace con las TTP compartidas?
3. Seleccionamos métricas que no sólo se puedan obtener, sino que superen la prueba de relevancia, accionabilidad y rentabilidad.

El resultado es un conjunto de indicadores que no se limitan a contar incidentes y vulnerabilidades, sino que informan sobre la calidad de la detección. Para un país, esto significa tener algo más que gráficos de “incidentes gestionados”: significa saber si el esfuerzo colectivo está erosionando realmente la capacidad operativa de quienes atacan.

Y a nivel de organización, ¿qué cambia?

Desde la perspectiva de una empresa u organismo, la combinación de GQM y PRAGMATIC ofrece un antídoto contra la sobrecarga de métricas:

- En lugar de aceptar todas las métricas que salen “de serie” de las herramientas, se seleccionan aquellas que responden a objetivos propios.
- En lugar de agregar sin más números de alertas, se pregunta cuántas de ellas corresponden a detecciones de alto nivel, y qué diferencia marcan.
- En lugar de presentar al Consejo “incidentes bloqueados” como si fueran goles marcados, se empieza a hablar de “hábitos adversarios que hemos cambiado”.

No es magia, pero sí introduce una forma distinta de conversación: menos basada en volumetría y más en calidad de fricción.

Epílogo: la métrica como contrato

En el fondo, cada métrica es un pequeño contrato entre quienes producen datos y quienes toman decisiones. GQM ayuda a redactar el contrato en lenguaje comprensible: esto es lo que queremos lograr, así vamos a preguntárnoslo, estos son los números que usaremos como brújula. PRAGMATIC, por su parte, revisa la letra pequeña: ¿merece la pena este contrato, o estamos firmando por costumbre?

La Pirámide del Dolor se beneficia de este doble enfoque porque su esencia es precisamente la discriminación: no todo indicador vale lo mismo. Si al terminar de aplicar este marco uno descubre que algunas de las métricas que siempre había perseguido puntúan muy bajo en PRAGMATIC, no es mala señal: quizá sea la oportunidad perfecta para dejar de medir por inercia y empezar a medir por intención.